Product-Technology Traceability Matrix

Product: Internet Banking Concept Microservices
Repository: Persistent-Systems-Test/ts-java-spring-boot-internet-banking
Baseline: main @ fa1c445
Assessment date: 2026-11-03
Prepared by: Devin (AI), evidence-based automated assessment

Product-Technology Traceability Matrix

Product Capability	Product Finding	Technology Component	Technology Finding	Business Impact	Recommendation
CAP-05 Intra-bank fund transfer	PDD-F-01	core-banking TransactionService; request DTOs	TDD-CQ-02, TDD-SEC-07	Theft via negative amounts	Validation + ledger invariants (Phase 0)
CAP-05 Intra-bank fund transfer	PDD-F-02	Fund-transfer orchestrator; gateway; missing entitlement layer	TDD-SEC-02, TDD-ARC-03, TDD-SEC-04	Unauthorised debits	Per-service JWT validation + ownership checks
CAP-05 / CAP-06 Ledger postings	PDD-F-03	Gateway route /banking-core/**	TDD-ARC-02	Bypass of channel controls	Remove route; internal-only core
CAP-04 / CAP-05 Balances	PDD-F-04	TransactionService balance arithmetic; BankAccountEntity	TDD-DAT-01, TDD-DAT-02, TDD-CQ-05	Wrong balances, overdrafts	Fix arithmetic, locking, tests asserting balances
CAP-07 History / CAP-04 Lookup	PDD-F-05	FundTransferService/UtilityPaymentService findAll; AccountService	TDD-SEC-02, TDD-SEC-12	Privacy breach	Customer-scoped queries; log masking
CAP-02 Registration approval	PDD-F-06, PDD-F-12	User service UserController/UserService ; Keycloak realm	TDD-SEC-03, TDD-CQ-07, TDD-SEC-05	Self-approval; blocked users still log in; password leakage	RBAC + maker-checker; sync lifecycle to IdP; redact logs
CAP-05 Fund transfer	PDD-F-07	TransactionService status rules	TDD-DAT-03	Frozen accounts transact	Status checks in ledger
CAP-05 / CAP-06 Payment lifecycle	PDD-F-08, PDD-F-09	Orchestrators + Feign	TDD-ARC-01, TDD-DAT-04, TDD-REL-01	Stuck/duplicate payments	Saga, outbox, idempotency, circuit breakers
CAP-06 Utility payment	PDD-F-10	core utilPayment; no biller adapter	TDD-ARC-06, TDD-DAT-08	Customer debited without settlement	Biller adapter + settlement GL
CAP-03 Authentication	PDD-G-02	Keycloak 23 realm, gateway	TDD-SEC-09, TDD-STK-02, TDD-SEC-11	Account takeover; regulatory non-compliance (SCA)	Hardened, upgraded Keycloak with MFA + rate limiting
CAP-09 Audit	PDD-G-02	AuditAware, gateway X-Auth-Id filter	TDD-ARC-07, TDD-DAT-05	Untrustworthy audit trail	Fix propagation; immutable audit stream
Platform configuration	PDD-R-01, PDD-S-01	Config Server -> external repo; javatodev/* images	TDD-SEC-06, TDD-INF-04, TDD-ARC-08	Third-party control of production behaviour	Internalise config and image builds
All capabilities (credentials)	PDD-R-05	docker-compose, realm-export, test yml, README	TDD-SEC-01	Trivial compromise of default deployments	Rotate + secrets manager
Ledger data	PDD-R-04	Flyway temp_data migration	TDD-DAT-07	Fake customers in prod	Test-only migration location
CAP-11 Notifications	PDD-G-01	No broker	TDD-ARC-05, TDD-STK-04	No customer alerts	Event bus + notification service
Integrator APIs	PDD-A-03	Postman, DTOs, springdoc	TDD-STK-03, TDD-CQ-06, TDD-ENG-05, TDD-CQ-04	Integration friction	Published OpenAPI contracts; regenerate Postman

Product Capability	Product Finding	Technology Component	Technology Finding	Business Impact	Recommendation
Real core / rails	PDD-A-02	Simulated core	TDD-ARC-06	Unbounded integration effort	Adapter contracts
Error handling (all)	PDD-E-02	GlobalExceptionHandler x4	TDD-CQ-03	Poor UX; info disclosure	ProblemDetail
Multi-bank / scale	PDD-S-02	Single MySQL, single realm, compose	TDD-ARC-04, TDD-INF-02, TDD-SCA-01, TDD-REL-02	Cannot scale commercially	K8s, per-service DBs, HA; tenancy decision
Product evolution	PDD-S-03, PDD-R-03	Ledger model; duplicated code; fragmented builds	TDD-DAT-05, TDD-CQ-01, TDD-ENG-02, TDD-STK-01	Slow feature delivery	Ledger generalisation; shared starter; upgrades
CAP-05 Fund transfer (same-account)	PDD-F-11	Request validation	TDD-CQ-02	Ledger noise; limit gaming	from != to validation
Account dashboard	PDD-E-03	Missing customer-scoped accounts query; entitlement model	TDD-SEC-02, TDD-ARC-03	Basic journey missing	Accounts query API on top of entitlement layer
Customer UI / accessibility	PDD-E-01, PDD-E-04	No front-end component in repository	- (outside repository scope)	Cannot pilot with customers	Build web/mobile channel (outside current codebase)
Quality assurance	PDD-F-04	Test suite	TDD-ENG-01, TDD-INF-01	Defects reach customers	Test pyramid + CI gates
Business continuity	PDD-R-01	Storage, DR	TDD-DAT-09, TDD-REL-05	Data loss / long outages	Backups, PITR, DR plan

PDD findings without a technology counterpart

PDD finding	Reason
PDD-A-01	Strength (channel/core separation) - preserved in target architecture (TDD target state)
PDD-C-01	Strength (accelerator value) - no technology deficiency
PDD-C-02	Business information gap - requires stakeholder validation
PDD-R-02	Licensing/branding - legal/commercial, not technical

Product capabilities with insufficient technical support

- CAP-05 (validation, ownership, locking)
- CAP-06 (no biller/settlement)
- CAP-07 (no scoping)
- CAP-11 (no broker)
- CAP-12 (no metrics/K8s)

Technology limitations affecting product functionality

- TDD-ARC-01 sync non-atomic writes -> stuck payments
- TDD-ARC-06 simulated core -> no real accounts
- TDD-DAT-05 mutable ledger -> no statements/audit

Product scalability constraints caused by architecture

- TDD-DAT-02 ledger locking
- TDD-ARC-04 shared DB
- TDD-REL-02 single instances
- TDD-INF-02 no orchestrator

Security gaps affecting product capabilities

- TDD-SEC-01..07 (all Critical) affect CAP-01..07
- TDD-SEC-09 affects CAP-03
- TDD-ARC-07 affects CAP-09

Technical debt affecting product evolution

- TD-02 distributed transactions
- TD-05 duplication/builds
- TD-06 schema management
- TD-08 framework currency

Modernisation opportunities

- MOD-01..MOD-08 (see TDD technology roadmap)

Coverage check

Every PDD finding is referenced in this matrix or listed above; every TDD finding with PDD references links back to an existing PDD finding; every TDD finding is scheduled in the technology roadmap.

Limitations and information gaps

- Static analysis only - services were not executed end-to-end; findings marked Medium confidence (e.g. TDD-ARC-07) should be confirmed at runtime.
- `./gradlew test` with JDK 21 could not complete: Maven Central returned HTTP 429 (rate limit) during dependency resolution in the assessment environment. Test pass/fail status and dependency CVE scan are therefore not available.
- Runtime configuration lives in an external, third-party repository; it was reviewed at its current HEAD, which the services do not pin.
- Technology lifecycle/support statements were not re-verified online (confidence Medium).
- Business data (customers, revenue, KPIs, market share, adoption, SLAs, incidents) is not in the repository and has not been estimated.
- The 35-item capability reference list and effort/timeline estimates are assessor judgement, not market or benchmark data.
- No UI exists; accessibility could not be assessed.